6. Threat vs Vulnerability vs Risk vs Exploit

These four words get mixed up a lot. The easiest way to see it: think of a house.

Term	Meaning	Example
Threat	Anything that could cause harm to an asset	A ransomware group targeting hospitals
Vulnerability	A weakness that a threat can use	An unpatched Windows server with a known SMB flaw
Exploit	The actual method or code that takes advantage of a vulnerability	The EternalBlue exploit used against that SMB flaw
Risk	The chance that a threat uses a vulnerability, combined with the damage it would cause	A hospital server exposed to the internet with that flaw has a high risk of a ransomware attack and patient data loss

House example

- Threat: a burglar in the neighbourhood
- Vulnerability: the back door lock is broken
- Exploit: the burglar uses a crowbar on that lock
- Risk: the chance the burglar breaks in, multiplied by how much you lose

Key points

- **Risk = Threat x Vulnerability x Impact** (a common way to think about it)
- No vulnerability means a threat cannot do much. No threat means a vulnerability may just sit there. Risk needs both.
- You can reduce risk by patching (fix the vulnerability), monitoring (detect the threat) or limiting impact (backups, segmentation).
- Risk can be accepted, reduced, transferred (insurance) or avoided.
- Vulnerabilities are tracked with CVE IDs and scored with CVSS.